



**IMPLEMENTACIÓN DE UNA INFRAESTRUCTURA DE RED JERÁRQUICA Y
SISTEMAS DE MONITORIZACIÓN CRÍTICA PARA LA PYME FISCALBUNKER.**

Jose Carlos Torres y Lara Sánchez Sánchez

Grado Superior de Administración de Sistemas Informáticos en Red, The Power

Profesor Jesús Niño Camazon

5 de abril de 2026

Índice

1. ABSTRACT	5
1.1 English	5
1.2 Castellano	5
2. Introducción	6
3. Análisis del Entorno de la Gestoría	7
3.1. Estructura y Composición de Fiscal Bunker	7
3.2. Activos Críticos y Protección de la Información	8
4. Justificación del proyecto	9
4.1. Motivación y Estado de la Cuestión	9
4.2. Problemas Específicos y Soluciones Propuestas.....	9
4.2.1. Mitigación de Ransomware y Estrategia de Continuidad.....	9
4.2.2. Control de Identidades y Principio de Mínimo Privilegio	10
4.2.3. Monitorización Activa y Detección de Amenazas	10
5. Objetivos	11
5.1. Objetivo Principal	11
5.2. Objetivos Específicos	11
6. Planificación Técnica (RFTP)	13
6.1. R01: Segmentación de Red y VLANs	13
6.2. R02: Conectividad, Enrutamiento y Servicios de Datos	13
6.3. R03: Auditoría de Seguridad y Monitorización.....	14
7. DISEÑO DE LA INFRAESTRUCTURA TÉCNICA.....	15

7.1. Arquitectura de Red y Topología Jerárquica.....	16
7.2 Estándar IEE 802.1Q: Implementación de enlaces troncales	17
7.3. Inventario de Dispositivos de Networking	18
Tabla 1. Dispositivos de networking y consola de administración.....	19
7.4 Plan de Direccionamiento IP y Segmentación por Departamentos	20
Tabla 2. Servidores de datos, identidad y seguridad.....	21
7.5 Configuración de los puestos de trabajo.....	22
Tabla 3. Configuración de estaciones de trabajo por departamento.....	22
7.5 Casos de uso y validación del sistema.....	23
8. ESPECIFICACIÓN DE MÁQUINAS VIRTUALES Y ROLES DE SERVICIO	27
8.1. Nodo de Seguridad Perimetral: pfSense.....	27
8.2. Nodo de Controlador de Dominio: Windows Server (AD DS).....	27
8.3. Nodo de Servidor de Datos y Backup (Ubuntu Server).....	28
8.4 Nodo de Centro de Operaciones de Seguridad (SOC): Wazuh Manager.....	28
8.5. Estaciones de Trabajo: Windows 11 Pro	29
8.6 Nodo de Auditoría y Pentesting: Kali Linux.....	30
9. Documentación Técnica Complementaria y Evidencias (GitHub)	31
9.1 Acceso al repositorio	31
10. Implementación del Core de Seguridad: pfSense Firewall	32
10.1. Configuración de Interfaces y VLANs.	32
10.2. Políticas de Filtrado (Firewall Rules).....	32
11. Despliegue de Estaciones de Trabajo: Windows 11 Pro	33
11.1. Optimización y Hardening del Sistema	33

11.2. Validación de Conectividad	33
12. Gestión de Identidades: Windows Server y Active Directory	34
12.1. Estructura de Unidades Organizativas (OU).....	34
12.2. Seguridad del Dominio.....	34
13. Persistencia de Datos: Servidor Ubuntu y MariaDB	35
13.1. Configuración de MariaDB.....	35
13.2. Privilegio Mínimo en Base de Datos.....	35
14. Monitorización Proactiva: Sistema SIEM Wazuh	36
14.1. Despliegue del Manager y Dashboard	36
14.2. Despliegue de Agentes	37
15. Auditoría de Seguridad y Validación del Perímetro.....	39
15.1. Análisis de Visibilidad y Reconocimiento Externo	39
15.2. Verificación de la Estanqueidad de la Red Interna (LAN)	39
15.3. Evaluación de Resiliencia ante Ataques de Inundación (SYN Flood).....	40
15.4 Detección de Escalada de Privilegios	41
15.5 Análisis de ataques de fuerza bruta sobre SMB	42
15.6. Conclusiones de la validación técnica.....	43
16.TECNOLOGÍA	44
17.METODOLOGÍA	46
18.TRABAJOS FUTUROS	48
19.CONCLUSIONES	49
20.REFERENCIAS	50

1. ABSTRACT

1.1 English

This project covers the design, deployment, and security auditing of a comprehensive network and systems infrastructure for the tax consultancy Fiscal Bunker. As a newly established SME handling highly sensitive financial data and payroll processing, the company requires a high-security environment built under the "Digital Bunker" concept. The solution implements a segmented hierarchical network using VLANs to minimize the attack surface and prevent lateral movement. The core of the infrastructure is protected by a pfSense firewall and a Wazuh SIEM for proactive monitoring. Furthermore, the resilience of the system has been validated through penetration testing (including DoS and reconnaissance attacks), ensuring that the design is not only theoretical but battle-tested. This approach guarantees business continuity and the integrity of client information through a resilient, scalable, and audited architecture.

1.2 Castellano

El presente proyecto aborda el diseño, despliegue y auditoría de seguridad de una infraestructura integral de red y sistemas para la gestoría Fiscal Bunker. Esta pyme, dedicada a la gestión de datos financieros sensibles y procesamiento de nóminas, requiere un entorno tecnológico de alta seguridad basado en el concepto de "Búnker Digital". La solución propuesta estructura la red de forma jerárquica y segmentada mediante el uso de VLANs, reduciendo la superficie de ataque y evitando movimientos laterales de amenazas. La infraestructura se apoya en un cortafuegos pfSense y un sistema SIEM (Wazuh) para la monitorización proactiva. Además, la robustez del sistema ha sido validada mediante pruebas de intrusión y estrés (escaneos Nmap y ataques DoS), demostrando la capacidad de respuesta real del búnker ante incidentes. El resultado es una arquitectura resiliente y auditada, capaz de asegurar la operatividad de la gestoría y la integridad de la información de sus clientes.

2. Introducción

La función principal de este proyecto es el diseño y despliegue de una infraestructura de red y sistemas blindados, dotada de capacidades de monitorización avanzada. Mediante el uso de herramientas de virtualización, simularemos un entorno empresarial real que nos permita realizar auditorías de seguridad y validar la resistencia de la plataforma. Para llevar a cabo este diseño, se han analizado variables críticas como el presupuesto disponible, los recursos necesarios para la prestación de servicios y la modalidad de trabajo de los empleados (presencial, híbrida o remota).

3. Análisis del Entorno de la Gestoría

3.1. Estructura y Composición de Fiscal Bunker

La organización objeto de este proyecto cuenta con una plantilla de 18 empleados. Esta estructura define la estrategia de segmentación de red mediante VLANs y la jerarquía de Unidades Organizativas (OU) en el Active Directory, aplicando políticas de grupo (GPOs) diferenciadas por perfil:

- *Departamento fiscal y contable.* Compuesto por una Jefa de Departamento, cuatro contables Senior, dos Junior y un becario. Su labor requiere acceso recurrente a la base de datos MariaDB. Bajo el principio de mínimo privilegio, sus perfiles de usuario están limitados a permisos de consulta y edición básica, restringiendo funciones de administración a nivel de base de datos.
- *Departamento laboral y RRHH.* Formado por una responsable y tres técnicos. Gestionan información de alta sensibilidad (nóminas, contratos y datos de salud). Custodian los certificados digitales de los clientes; su "llave privada" reside de forma segura en el servidor de archivos, con acceso auditado y restringido.
- *Administración y recepción.* Compuesto por una secretaria de dirección y dos administrativas. Al ser el primer punto de contacto externo y gestionar la digitalización de facturas, su alta dependencia del correo electrónico las convierte en el vector de ataque principal (Phishing). Por ello, su VLAN tiene reglas de filtrado de navegación más estrictas en el pfSense.
- *Dirección.* Liderado por las dos socias fundadoras. Su perfil de alto cargo (C-Level) las posiciona como objetivos de ataques dirigidos (Whaling). Sus terminales cuentan con políticas de seguridad reforzadas para evitar la exfiltración de decisiones estratégicas.

- *IT (Administración de sistemas)*. Departamento desde donde se gestiona la infraestructura, el SOC y la ciberseguridad. Al poseer privilegios elevados (Domain Admin), se extrema la protección de las credenciales mediante el aislamiento de su segmento de red y la monitorización constante a través de Wazuh.

3.2. Activos Críticos y Protección de la Información

Para Fiscal Bunker, la seguridad no es solo una opción técnica, sino una obligación legal y operativa. Los activos críticos identificados son:

1. *Datos de identidad y privacidad*. DNIs, direcciones y vidas laborales de los clientes de la gestoría, sujetos a la normativa LOPDGDD/RGPD.
2. *Activos financieros y tributarios*. Cuentas bancarias, declaraciones de impuestos y balances contables alojados en el servidor de datos.
3. *Certificados digitales y credenciales*. Elementos esenciales para la representación de terceros ante la Sede Electrónica de la AEAT y la Seguridad Social. Su pérdida o robo comprometería la responsabilidad legal de la firma.
4. *Disponibilidad del servicio*. La infraestructura de red y servidores debe ser resiliente; cualquier parada técnica en periodo de liquidación de impuestos supondría sanciones económicas graves para los clientes y daños reputacionales para la gestoría.

4. Justificación del proyecto

4.1. Motivación y Estado de la Cuestión

La motivación de este proyecto surge de la vulnerabilidad crítica de las PYMES en el ciberespacio actual. Según el Instituto Nacional de Ciberseguridad (INCIBE), los incidentes gestionados han alcanzado cifras récord, con un aumento del 26% en el último año. El impacto económico medio de un ciberataque para una PYME española se sitúa en los 75.000 euros, una cifra que para una gestoría de reciente creación supondría, con alta probabilidad, el cese definitivo de su actividad.

4.2. Problemas Específicos y Soluciones Propuestas

Los balances recientes de ciberseguridad muestran que el fraude online y el robo de datos confidenciales han crecido exponencialmente (171% en el último periodo reportado). Las asesorías, por el alto valor de la información fiscal y laboral que custodian, son objetivos prioritarios. Para mitigar estos riesgos, el proyecto implementa soluciones técnicas de "Defensa en Profundidad":

4.2.1. Mitigación de Ransomware y Estrategia de Continuidad

- *Segmentación de red.* La implementación de VLANs mediante el estándar 802.1Q garantiza que, si un ataque de Phishing compromete un equipo de Administración, el malware quede confinado en ese segmento lógico. Esto impide el movimiento lateral hacia el departamento Fiscal o los servidores centrales.
- *Resiliencia de datos.* Para asegurar la continuidad de negocio, se despliega un servidor de archivos basado en Ubuntu Server con redundancia de datos. Se ha priorizado una configuración que equilibre la seguridad con la sostenibilidad económica para la empresa.

- *Estrategia de backup.* Mediante herramientas de respaldo profesional, se realizan snapshots y copias incrementales de las bases de datos MariaDB. Esta estrategia asegura que, ante un incidente de cifrado o borrado accidental, la gestoría pueda recuperar su operatividad en un tiempo mínimo (RTO reducido).

4.2.2. Control de Identidades y Principio de Mínimo Privilegio

Mediante el despliegue de Active Directory (AD DS), se centraliza la gestión de permisos y políticas de grupo (GPOs). Esto elimina las vulnerabilidades derivadas del error humano y asegura que cada empleado acceda exclusivamente a los recursos necesarios para su función técnica. Este control estricto facilita, además, el cumplimiento normativo de la LOPDGDD.

4.2.3. Monitorización Activa y Detección de Amenazas

La seguridad pasiva se complementa con una capa de monitorización basada en Wazuh (SIEM/HIDS). El despliegue de agentes en los *endpoints* permite centralizar los registros de eventos y procesos en un panel de control unificado. Al analizar los logs del *firewall* pfSense y de los servidores en tiempo real, es posible identificar comportamientos sospechosos (como intentos de fuerza bruta o escaneos de red) y generar alertas para intervenir antes de que se produzca una filtración de datos real.

5. Objetivos

5.1. Objetivo Principal

El objetivo principal de este proyecto es el diseño, configuración y auditoría de una infraestructura de red y sistemas blindados para la gestoría Fiscal Bunker. Se busca garantizar la confidencialidad de la información tributaria y la disponibilidad de los servicios críticos mediante una arquitectura de defensa en profundidad.

5.2. Objetivos Específicos

Para alcanzar este propósito, se han definido y ejecutado los siguientes objetivos específicos:

- *Segmentación de red y aislamiento lógico.* Implementar una arquitectura conmutada basada en el estándar IEEE 802.1Q. El fin es segregar el tráfico de los diferentes departamentos (Fiscal, Laboral, Administración, Dirección e IT) mediante VLANs, limitando los dominios de difusión y evitando movimientos laterales de posibles amenazas.
- *Seguridad perimetral y enrutamiento.* Configurar un clúster de seguridad basado en pfSense que gestione el enrutamiento inter-VLAN y el acceso a internet. Se han aplicado políticas de filtrado estricto (Stateful Inspection) para permitir únicamente las comunicaciones autorizadas hacia el servidor de datos.
- *Gestión de identidades y persistencia de datos.* Establecer un dominio de Active Directory para la gestión centralizada de usuarios y desplegar una base de datos MariaDB bajo un entorno endurecido (hardening), asegurando que la información de la gestoría resida en un segmento protegido.

- *Monitorización y visibilidad.* Desplegar una solución de gestión de eventos (SIEM) mediante Wazuh. El objetivo es validar la conectividad de agentes en los endpoints para centralizar la recepción de logs y sentar las bases de una monitorización proactiva de la red.
- *Validación y auditoría de seguridad (Pentesting).* Someter la infraestructura a pruebas de estrés y escaneos de vulnerabilidades utilizando Kali Linux. Este objetivo busca confirmar la resiliencia del búnker ante ataques de denegación de servicio (DoS) y asegurar que el perímetro sea invisible ante reconocimientos externos no autorizados.

6. Planificación Técnica (RFTP)

6.1. R01: Segmentación de Red y VLANs

- *R01F01 – Implementación de VLANs (Virtual local area networks).*
 - R01F01T01 – Crear las VLANs 10, 20, 30, 40, 50 y 60 en la infraestructura de switching.
 - R01F01T01P01 – Ejecutar el comando show vlan brief y verificar la asignación de nombres y puertos.
- *R01F02 – Configuración de enlaces troncales.*
 - R01F02T01 – Configurar puertos Gigabit como Trunk bajo el estándar 802.1Q para el transporte de etiquetas.
 - R01F02T01P01 – Ejecutar show interfaces trunk y comprobar que el estado es "trunking" y las VLANs están permitidas.

6.2. R02: Conectividad, Enrutamiento y Servicios de Datos

Los departamentos deben poder comunicarse con los servicios centrales y acceder a internet bajo políticas de filtrado.

- *R02F01 – Enrutamiento inter-VLAN y gateway.*
 - R02F01T01 – Configurar las interfaces virtuales en pfSense como puertas de enlace para cada segmento.
 - R02F01T01P01 – Realizar pruebas de ping desde los puestos de trabajo (VLAN 20-50) hacia su respectivo Gateway.
- *R02F02 – Despliegue de base de datos y persistencia.*
 - R02F02T01 – Instalación de la pila LAMP/MariaDB en el nodo Ubuntu Server (VLAN 10).
 - R02F02T01P01 – Verificar el estado del servicio mediante systemctl status mariadb y comprobar el rechazo de conexiones externas no autorizadas.

6.3. R03: Auditoría de Seguridad y Monitorización

El sistema debe ser validado ante ataques y permitir la visibilidad centralizada de los activos.

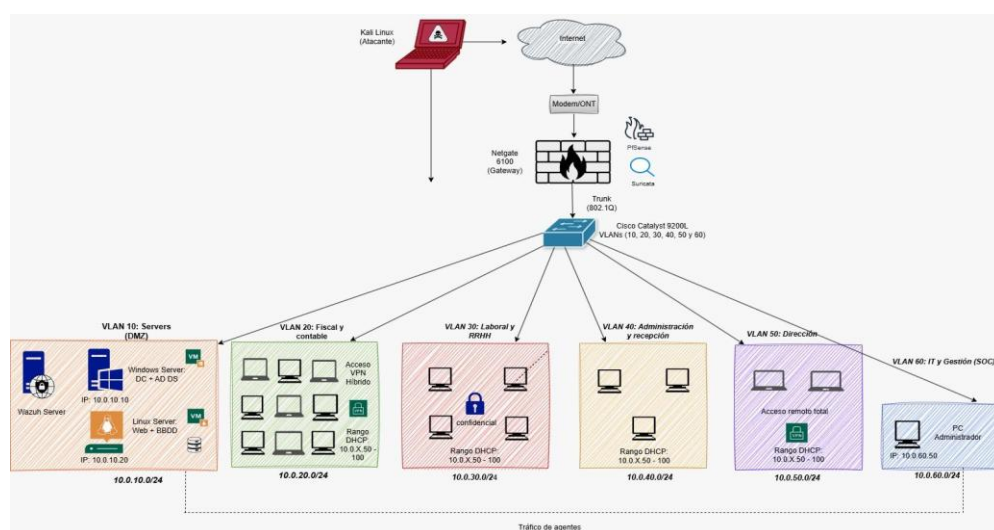
- *R03F01 – Monitorización y gestión de eventos (SIEM).*
 - R03F01T01 – Despliegue del Wazuh Manager y prueba de instalación de agentes en los endpoints.
 - R03F01T01P01 – Verificar en el dashboard de Wazuh que el agente aparece en estado *Active*.
 - R03F01T02 – Simulación de persistencia y escalada de privilegios mediante la creación de un usuario administrador local no autorizado en Windows 11.
 - R03F01T02P01 – Verificar en el panel de alertas de Wazuh la detección inmediata de las modificaciones en los registros de seguridad correspondientes a la creación de cuenta y asignación de privilegios.
- *R03F02 – Pruebas de intrusión y pentesting (Kali Linux).*
 - R03F02T01 – Ejecución de escaneos de red con Nmap para validar el endurecimiento del firewall.
 - R03F02T02 – Simulación de ataque DoS mediante hping3 para comprobar la resiliencia del búnker.
 - R03F02T01P01 – Analizar los logs de PfSense para confirmar el bloqueo y descarte de tráfico malicioso.
 - R03F02T03 – Ejecución de ataque de fuerza bruta automatizado sobre el protocolo SMB (puerto 445).
 - R03F02T03P01 – Comprobar en el panel Threat Hunting de Wazuh el registro masivo de alertas de autenticación fallida (gravedad 12) y su correspondiente mapeo en el marco MITRE ATT&CK.

7. DISEÑO DE LA INFRAESTRUCTURA TÉCNICA

A continuación, se desglosan los activos críticos representados en la arquitectura de Fiscal Bunker. Este esquema detalla la función operativa, el sistema operativo y la ubicación lógica de cada nodo dentro del direccionamiento IP. Toda la infraestructura se sustenta en el estándar IEEE 802.1Q, protocolo responsable del etiquetado de tramas (VLAN Tagging). Esta configuración es la que permite que el tráfico de los 18 empleados viaje de forma segregada y segura a través de la misma infraestructura física, garantizando que los dominios de difusión permanezcan aislados y protegidos según las políticas de seguridad establecidas.

Figura 1

Diagrama de la arquitectura lógica y segmentación de red de FiscalBunker



Nota. El diagrama muestra como usamos el estándar 802.1Q para separar el tráfico de los departamentos y conectar los servidores de forma segura.

7.1. Arquitectura de Red y Topología Jerárquica

Se ha implementado una red basada en un modelo de diseño jerárquico (Acceso, Distribución y Núcleo), utilizando una topología en estrella. Este diseño permite centralizar la administración de la seguridad y facilita la escalabilidad modular de la gestoría.

El núcleo de la red (Core) está compuesto por una switch multicapa que actúa como el nodo central de distribución. Este dispositivo centraliza el tráfico de los seis departamentos, los cuáles han sido configurados como entornos estancos y segmentados mediante VLANs (IEEE 802.1Q) para garantizar el aislamiento de datos y la eficiencia del tráfico de broadcast.

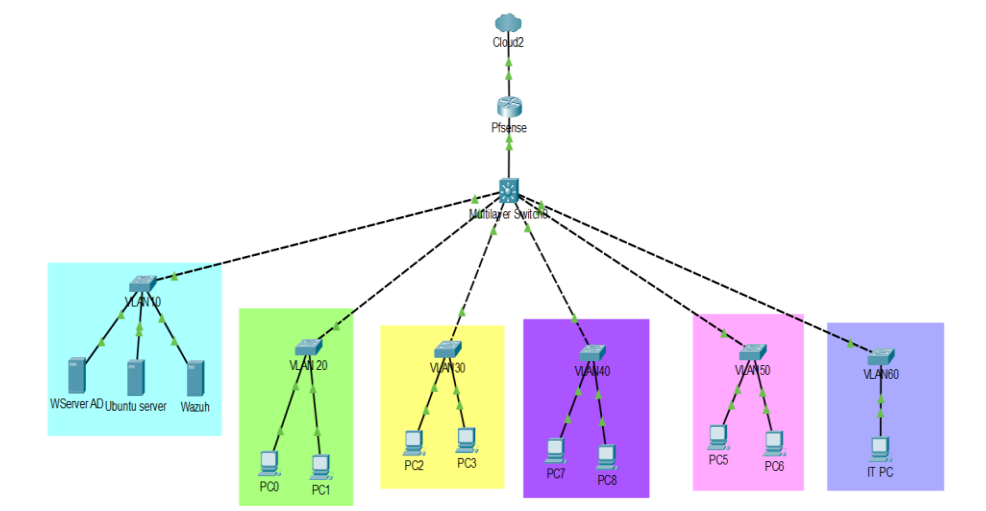
Esta sección detalla la organización de los activos de red y los puestos operativos:

- *Capa de núcleo y distribución.* Representada por el Multilayer Switch, que interconecta todas las VLANs configuradas. Este nodo es el responsable de gestionar los enlaces troncales hacia la capa de acceso y de dirigir el tráfico hacia el firewall pfSense para su inspección perimetral.
- *Capa de acceso.* Formada por los switches dedicados a cada VLAN, donde se conectan los equipos finales. Su función operativa es asegurar que cada puerto físico esté asignado a su red lógica correspondiente, como el switch de la VLAN 60 que da conectividad al equipo "IT PC" para las tareas de gestión.
- *Segmentación de red.* Como se observa en el diagrama, cada departamento opera en su propia red lógica, lo que impide que un problema de seguridad en un puesto de trabajo se propague al resto de la infraestructura, cumpliendo con el principio de mínimo privilegio.

Al centralizar todas las VLANs en la switch multicapa, se optimiza el rendimiento del enrutamiento inter-VLAN y se asegura que la comunicación entre los puestos de trabajo y los servidores centrales se realice con la menor latencia posible.

Figura 2

Topología de red y segmentación por departamentos



Nota. El diagrama representa la organización de la red en capas, mostrando la interconexión de las seis VLANs en Packet Tracer.

7.2 Estándar IEE 802.1Q: Implementación de enlaces troncales

Para dar soporte técnico a esta segmentación, se utiliza el estándar ieee 802.1q, también conocido como dot1q. Este protocolo permite el etiquetado de tramas ethernet, insertando un identificador de vlan de 32 bits en la cabecera original. Gracias a esta tecnología, es posible transportar múltiples redes virtuales a través de un único enlace físico entre los switches y el router, garantizando que los datos de un departamento no sean visibles para los demás a menos que se defina una regla específica de enrutamiento (cisco, 2023).

7.3. Inventario de Dispositivos de Networking

Los dispositivos utilizados para conformar la infraestructura de Fiscal Bunker han sido seleccionados para garantizar alta disponibilidad y seguridad perimetral. En la fase actual de implementación, se han configurado los siguientes elementos:

- *Firewall / gateway (PfSense)*. Actúa como el núcleo de seguridad y puerta de enlace predeterminada. Su función principal es el enrutamiento inter-VLAN, aplicando políticas de filtrado estrictas que regulan la comunicación entre departamentos y el acceso a los servicios centrales.
- *Switch Core (Multicapa)*. Funciona como el nodo central de distribución. Gestiona los enlaces troncales (trunks) y asegura que el etiquetado de las VLANs bajo el estándar IEEE 802.1Q se mantenga íntegro en toda la infraestructura.
- *Switches de acceso*. Dispositivos dedicados a la conectividad de los equipos finales. Su función operativa es la asignación de puertos físicos a sus redes lógicas correspondientes mediante seguridad de puerto (Port-Security).
- *Servidores y estaciones de trabajo*. Equipos finales donde residen los servicios críticos (VLAN 10) y los puestos operativos de los empleados distribuidos entre las VLANs 20 y 60.

Tabla 1. Dispositivos de networking y consola de administración

Dispositivo	Modelo / SO	Función Principal	VLAN	Dirección IP
Firewall / GW	Netgate (pfSense)	Filtrado y Enrutamiento.	Trunk	192.168.1.147 (WAN) / 10.0.1.1 (LAN)
Switch Core	Cisco Catalyst	Segmentación 802.1Q.	Gestión	10.0.1.254 (Gestión)
PC Administrador	Windows 11 Pro	Gestión del SOC y Firewall.	60 (Gestión IT)	10.0.6.20

Durante las fases iniciales de despliegue, el PC de administrador operó en la VLAN 10 para facilitar las pruebas básicas de conectividad. Sin embargo, para la fase de auditoría final (100%) y la validación de seguridad con el SIEM, se optó por configurar temporalmente los adaptadores de red en modo puente (rango 192.168.1.x). De este modo, el servidor Wazuh operó con la IP 192.168.1.138 y el endpoint Windows con la IP 192.168.1.51. Esta decisión se tomó para garantizar la estabilidad de la máquina virtual (OVA) del SIEM y simular un entorno convergente que permitiera recibir la telemetría y detectar los ataques (fuerza bruta SMB y escalada de privilegios) de forma directa y sin bloqueos de enrutamiento intermedio. En su paso a producción definitiva, el PC de administración quedaría aislado y securizado en la VLAN 60 (IP 10.0.6.20).

Para la interconexión de los niveles de acceso y core, se han implementado enlaces troncales utilizando interfaces Gigabit Ethernet. Esta decisión técnica es fundamental para evitar cuellos de botella en la red, permitiendo el flujo simultáneo de múltiples redes lógicas a alta velocidad. Al centralizar este tráfico en la switch multicapa, se optimiza el rendimiento del enrutamiento inter-VLAN y se asegura que la comunicación entre los puestos de trabajo y el servidor de datos se realice con la menor latencia posible (Cisco, 2023).

7.4 Plan de Direccionamiento IP y Segmentación por Departamentos

La infraestructura de Fiscal Bunker se basa en un esquema de direccionamiento privado diseñado para maximizar la seguridad mediante el aislamiento jerárquico. Los sistemas críticos se ubican en la VLAN 10, un segmento restringido donde se centralizan los servicios de identidad, datos y monitorización. El acceso a esta red está limitado exclusivamente al personal de IT y a las reglas de filtrado del *firewall* pfSense, que actúa como puerta de enlace interna (10.0.1.1) y externa (192.168.1.147), permitiendo la comunicación específica y segura con las estaciones de trabajo.

Tabla 2. Servidores de datos, identidad y seguridad

<i>Servidor / Nodo</i>	<i>Sistema Operativo</i>	<i>Función Específica</i>	<i>VLAN</i>	<i>Dirección IP</i>
<i>PfSense (LAN)</i>	<i>FreeBSD</i>	<i>Gateway y Firewall (Inter – VLAN)</i>	<i>Management / Trunk</i>	<i>10.0.1.1 (virtual) / 192.168.1.147</i>
<i>Active Directory</i>	<i>Windows Server 2022</i>	<i>Controlador de dominio y AD DS</i>	<i>10 (servidores)</i>	<i>10.0.1.2</i>
<i>Base de Datos</i>	<i>Ubuntu Server</i>	<i>MariaDB y Almacenamiento.</i>	<i>10</i>	<i>10.0.1.3</i>
<i>Wazuh Manager</i>	<i>Wazuh Server (ova)</i>	<i>SIEM / Análisis de seguridad.</i>	<i>Bridge (auditoria)</i>	<i>191.168.1.51</i>
<i>Windows 11</i>	<i>Windows 11 Pro</i>	<i>Host de validación y gestion</i>	<i>Bridge (auditoria)</i>	<i>192.168.1.129</i>
<i>Kali Linux</i>	<i>Kali Linux</i>	<i>Auditoria pentesting</i>	<i>Bridge (auditoria)</i>	<i>192.168.1.129</i>

7.5 Configuración de los puestos de trabajo

Las estaciones de trabajo obtienen su configuración de red de forma dinámica a través del servicio DHCP configurado en el pfSense, lo que facilita la administración y escalabilidad de la gestoría. Cada departamento opera en una subred distinta (segmentos /24), evitando el tráfico innecesario entre áreas y reforzando la seguridad mediante el aislamiento lógico de los datos.

Tabla 3. Configuración de estaciones de trabajo por departamento

Departamento	Sistema Operativo	Rango de Red	VLAN	Rango DHCP
Fiscal y Contable	Windows 11	10.0.2.0/24	20	10.0.2.10 - .254
Laboral y RRHH	Windows 11	10.0.3.0/24	30	10.0.3.10 - .254
Administración	Windows 11	10.0.4.0/24	40	10.0.4.10 - .254
Dirección	Windows 11	10.0.5.0/24	50	10.0.5.10 - .254
Gestión IT	Windows 11 / Kali*	10.0.6.0/24	60	10.0.6.10 - .254

El nodo Kali Linux ha sido integrado en la infraestructura para la fase de auditoría final (100%) operando con la dirección IP 192.168.1.129. Al configurar el nodo en modo adaptador puente, se ha permitido su actuación como herramienta de gestión y auditoría interna, facilitando la ejecución de los ataques controlados (fuerza bruta SMB y DoS) y la validación de la monitorización en el SIEM.

7.5 Casos de uso y validación del sistema

Para verificar la robustez de la infraestructura de Fiscal Bunker, se han definido y ejecutado escenarios reales que el sistema debe gestionar correctamente. Estas pruebas validan que el diseño teórico cumple con las necesidades de seguridad de la gestoría.

- *Caso de uso 1.* Aislamiento departamental y control de acceso (VLANs)
 - Actor: Empleado del departamento Fiscal.
 - Escenario: El empleado intenta acceder a recursos restringidos en la VLAN de Servidores (VLAN 10) o de Recursos Humanos (VLAN 30).
 - Funcionamiento Técnico: Aunque la conectividad física es común, el tráfico está segmentado mediante el estándar IEEE 802.1Q. El firewall pfSense actúa como puerta de enlace única, aplicando reglas de filtrado Stateful que impiden el salto entre redes lógicas no autorizadas.
 - Resultado Obtenido: El tráfico es interceptado y descartado por el perímetro. La segmentación garantiza que la información sensible (nóminas o bases de datos) permanezca aislada, cumpliendo con el principio de mínimo privilegio.

- *Caso de uso 2. Auditoría de visibilidad perimetral (Pentesting)*
 - Actor: Atacante externo (simulado mediante Kali Linux).
 - Escenario: Intento de reconocimiento de red mediante un escaneo de puertos (Nmap) contra la interfaz WAN o activos internos para identificar vulnerabilidades.
 - Funcionamiento Técnico: El firewall pfSense ha sido configurado con una política de "Denegación por Defecto". Al recibir las ráfagas de paquetes SYN del escáner, el sistema no responde a las peticiones no autorizadas, manteniendo los puertos en estado filtered.
 - Resultado Obtenido: El atacante no logra obtener información sobre los servicios internos. Como se ha demostrado en las pruebas técnicas, el búnker permanece opaco ante el reconocimiento externo, mitigando la fase de preparación de un posible ciberataque.

- *Caso de uso 3. Resiliencia ante denegación de servicio (DoS)*
 - Actor: Atacante interno o externo (simulado mediante hping3).
 - Escenario: Inundación masiva de paquetes TCP SYN (SYN Flood) dirigida a saturar los recursos del servidor perimetral.
 - Funcionamiento Técnico: El motor de filtrado de pfSense gestiona la pila de conexiones entrantes. Durante la prueba de estrés, se monitoriza el uso de CPU y el tráfico de red para asegurar que el sistema no sufra un desbordamiento de búfer.
 - Resultado Obtenido: El firewall absorbe la carga de paquetes sin interrumpir el tráfico legítimo de la red. La monitorización en tiempo real confirma que los servicios de la gestoría siguen disponibles para los empleados a pesar del ataque, validando la alta disponibilidad del búnker.

- *Caso de uso 4. Verificación de monitorización (Wazuh)*
 - Actor: Administrador de Sistemas.
 - Escenario: Despliegue de un nuevo nodo en la red y necesidad de supervisión centralizada.
 - Funcionamiento Técnico: Se realiza la instalación del agente de Wazuh en una estación de trabajo o servidor. El agente establece una conexión segura con el Manager ubicado en la VLAN 10.
 - Resultado Obtenido: Se confirma la comunicación exitosa entre el agente y el panel de control. Esto establece la base necesaria para la futura recolección de logs y detección de anomalías, asegurando que el administrador tenga visibilidad sobre el estado de salud de los activos del búnker.

- *Caso de uso 5. Detección de persistencia y escalada de privilegios*

Actor: Administrador / Usuario malintencionado en el nodo Windows 11 (IP 192.168.1.51).

 - Escenario: Creación de una cuenta de usuario local no autorizada y su posterior inclusión en el grupo de administradores para obtener persistencia en el sistema.
 - Funcionamiento Técnico: El agente de Wazuh instalado en el endpoint monitoriza los registros de seguridad de Windows. Al realizarse la creación del usuario y el cambio de privilegios, el agente envía la telemetría al SIEM Manager (IP 192.168.1.138), el cual ha sido desplegado mediante una imagen OVA para garantizar la estabilidad del servicio.
 - Resultado Obtenido: El Dashboard de Wazuh genera alertas de nivel crítico, permitiendo identificar el evento de creación de cuenta y la elevación de privilegios. Esta prueba valida la visibilidad total sobre las acciones administrativas dentro del búnker.

- *Caso de uso 6. Respuesta ante ataques de fuerza bruta (SMB)*

Actor: Atacante interno simulado desde Kali Linux (IP 192.168.1.129).

- Escenario: Intento de acceso ilícito mediante un ataque de diccionario contra el protocolo SMB (puerto 445) utilizando la herramienta nmap.
- Funcionamiento Técnico: Se lanza un ataque masivo de intentos de conexión hacia el nodo Windows 11. El SIEM Manager recibe las ráfagas de fallos de autenticación procesadas por el agente. El sistema correlaciona estos eventos y dispara una regla de nivel 12 (gravedad crítica) al detectar el patrón de fuerza bruta.
- Resultado Obtenido: El administrador visualiza el ataque en tiempo real en el panel de *Threat Hunting*, obteniendo el origen del ataque (IP de Kali) y el mapeo de la técnica bajo el marco MITRE ATT&CK. Se confirma así la capacidad de detección temprana ante intentos de intrusión por adivinación de credenciales.

8. ESPECIFICACIÓN DE MÁQUINAS VIRTUALES Y ROLES DE SERVICIO

Para el despliegue del búnker digital de la gestoría, se han seleccionado y configurado seis entornos virtualizados. Cada nodo cumple una función crítica, utilizando sistemas operativos actualizados a estándares de 2026 y configuraciones de seguridad validadas mediante auditoría técnica.

8.1. Nodo de Seguridad Perimetral: pfSense

Este servidor actúa como el núcleo de seguridad de FiscalBunker, gestionando el tráfico entre el exterior y las zonas de confianza.

- *Segmentación lógica.* Implementación de 6 VLANs bajo el estándar IEEE 802.1Q para el aislamiento total de los departamentos.
- *Firewalling avanzado:* Control exhaustivo del flujo de paquetes mediante reglas de filtrado Stateful Inspection. Se ha configurado una política de "Denegación por Defecto", permitiendo únicamente el tráfico estrictamente necesario.
- *Defensa perimetral.* Durante las pruebas de auditoría, este nodo ha demostrado su capacidad para mitigar intentos de escaneo y saturación (DoS), protegiendo la integridad de los servidores internos.

8.2. Nodo de Controlador de Dominio: Windows Server (AD DS)

Ubicado en la VLAN 10 (Servidores), es el centro de gestión de identidades para los 18 empleados.

- *Gestión centralizada.* Organización de la empresa en Unidades Organizativas (OUs) con políticas de grupo (GPOs) que aseguran el cumplimiento de normativas de acceso.
- *Control de acceso (RBAC).* Implementación del principio de mínimo privilegio, garantizando que el acceso a la información sensible esté restringido según el rol del empleado.

- *Transferencia segura.* Configuración de canales cifrados para el intercambio de documentación técnica y legal entre los diferentes departamentos.

8.3. Nodo de Servidor de Datos y Backup (Ubuntu Server)

Eje central de la base de datos y la estrategia de recuperación local, protegido en la VLAN 10.

- *Base de datos MariaDB.* Configurada para rechazar conexiones externas, limitando el acceso exclusivamente a las VLANs autorizadas (Administración e IT).
- *Estrategia de backup Local:*
 - Snapshots y replicación: Uso de Veeam Backup para la creación de copias de seguridad incrementales automatizadas cada 4 horas.
 - Recuperación ante desastres: El sistema permite la restauración completa del servidor (sistema operativo y datos) en pocos minutos ante un fallo crítico de la máquina virtual.

8.4 Nodo de Centro de Operaciones de Seguridad (SOC): Wazuh Manager

Ubicado inicialmente en la VLAN 10, su despliegue final se ha consolidado mediante una imagen OVA (Open Virtual Appliance) configurada en modo adaptador puente (IP 192.168.1.138) para garantizar la estabilidad del sistema y la visibilidad total de los activos durante la fase de auditoría.

- *Validación de Despliegue y Telemetría.* Se ha completado con éxito la instalación y vinculación de los agentes en los endpoints (Windows 11 con IP 192.168.1.51). La comunicación ha sido verificada a través del Dashboard, confirmando el flujo constante de telemetría y logs de seguridad hacia el Manager.

- *Capacidad de Monitorización y Respuesta.* A diferencia de fases anteriores, el nodo ya opera en una fase de respuesta activa. Se ha validado su capacidad para identificar comportamientos anómalos en tiempo real, tales como la creación de usuarios no autorizados y la elevación de privilegios en el sistema operativo.
- *Análisis de Amenazas Avanzado (Threat Hunting).* El sistema ha demostrado su eficacia en la detección de ataques dirigidos, logrando identificar y clasificar con nivel de gravedad 12 (Crítico) intentos de fuerza bruta sobre el protocolo SMB realizados con la herramienta ncrack desde el nodo Kali Linux (IP 192.168.1.129). Los eventos detectados han sido mapeados automáticamente bajo el marco MITRE ATT&CK, proporcionando al administrador una capacidad de análisis forense inmediata y detallada.

8.5. Estaciones de Trabajo: Windows 11 Pro

Estandarizadas por su soporte de seguridad nativo y el uso del chip TPM para la custodia de certificados digitales de la AEAT.

- *VLAN 60 (IT).* Privilegios de mantenimiento y gestión técnica avanzada sobre la infraestructura.
- *VLAN 40 (Administración).* Acceso operativo a la base de datos para gestión de facturación, con restricciones de seguridad a nivel de tabla.
- *VLANs 20, 30 y 50 (Fiscal, Laboral, Dirección).* Entornos aislados con acceso limitado exclusivamente a las herramientas necesarias para su función específica.

8.6 Nodo de Auditoría y Pentesting: Kali Linux

Este nodo se consolida como la herramienta fundamental para validar la eficacia del búnker digital mediante técnicas de seguridad ofensiva, operando en la fase final con la dirección IP 192.168.1.129 bajo una configuración de adaptador puente.

- *Configuración técnica y herramientas.* Implementado con una suite de auditoría profesional, centrando su actividad en el uso avanzado de Nmap tanto para el descubrimiento de activos como para la explotación controlada de servicios mediante el motor de scripts de Nmap (NSE).
- *Auditoría de visibilidad y acceso.* Se ejecutaron escaneos de puertos que confirmaron que el perímetro de pfSense es opaco frente a intentos de reconocimiento externo e interno. Asimismo, se identificó la exposición controlada del puerto 445 (SMB) en los nodos internos, necesaria para proceder con las pruebas de validación de credenciales.
- *Pruebas de resiliencia (DoS).* Se realizó un ataque de inundación SYN Flood mediante hping3. La monitorización confirmó que el firewall gestiona la carga masiva de paquetes sin afectar la disponibilidad de la red interna, validando la estabilidad del búnker ante incidentes de denegación de servicio.
- *Validación de Defensa Activa (Fuerza Bruta SMB).* Como hito final de la auditoría, se ejecutó un ataque de diccionario contra el servicio SMB del endpoint Windows 11 utilizando los scripts de auditoría de Nmap. Esta acción permitió certificar que el entorno no solo detecta el escaneo, sino que el SOC genera alertas de nivel de gravedad 12 al identificar la naturaleza del ataque y la IP de origen del nodo Kali en tiempo real.

9. Documentación Técnica Complementaria y Evidencias (GitHub)

Debido a la naturaleza técnica y la extensión del despliegue realizado para la infraestructura de FiscalBunker, se ha habilitado un repositorio externo que contiene el anexo técnico detallado.

Este documento complementario es fundamental para la comprensión global del proyecto, ya que incluye:

- *Guía paso a paso.* Procedimientos detallados de instalación y configuración de cada nodo.
- *Evidencias de despliegue.* Capturas de pantalla, logs de sistema y registros de configuración real.
- *Validación de auditoría.* Resultados íntegros de los escaneos de Nmap y las alertas generadas en el dashboard de Wazuh.

9.1 Acceso al repositorio

En el siguiente repositorio de GitHub hemos recopilado todas las evidencias técnicas. Es el complemento ideal a esta memoria para comprobar cómo hemos implementado y auditado cada parte de FiscalBunker.

Enlace: <https://github.com/Torresguarnizo/Anexo-TFG-ASIR-LARA-Y-JOSE>

10. Implementación del Core de Seguridad: pfSense Firewall

El cortafuegos PfSense constituye la primera línea de defensa y el cerebro del enrutamiento del búnker. Su implementación permite transitar de una red abierta a un entorno de Confianza Cero (Zero Trust).

10.1. Configuración de Interfaces y VLANs.

Se han definido las interfaces lógicas correspondientes a cada departamento, asignando el direccionamiento IP detallado en la planificación. La interfaz WAN actúa como terminación del enlace externo, mientras que la LAN se segmenta mediante el estándar 802.1Q.

10.2. Políticas de Filtrado (Firewall Rules)

Se ha aplicado una política de denegación por defecto (Default Deny). Solo se permite el tráfico estrictamente necesario, como el acceso de la VLAN Fiscal al puerto 3306 del servidor de base de datos y la salida controlada a Internet para actualizaciones de seguridad.

Figura 3

Configuración de VLANs en PfSense

Interfaces		
WAN	1000baseT <full-duplex>	192.168.29.132
LAN	1000baseT <full-duplex>	10.0.1.1
SERVIDORES	1000baseT <full-duplex>	10.0.10.1
FISCALCONTABLE	1000baseT <full-duplex>	10.0.20.1
LABORALRRHH	1000baseT <full-duplex>	10.0.30.1
ADMINRECEPCION	1000baseT <full-duplex>	10.0.40.1
DIRECCION	1000baseT <full-duplex>	10.0.50.1
IT	1000baseT <full-duplex>	10.0.60.1

Nota. Configuración correcta de las VLANs en PfSense por departamento

11. Despliegue de Estaciones de Trabajo: Windows 11 Pro

El equipo de gestión IT basado en Windows 11 Pro actúa como la consola de administración centralizada desde la cual se supervisa toda la infraestructura.

11.1. Optimización y Hardening del Sistema

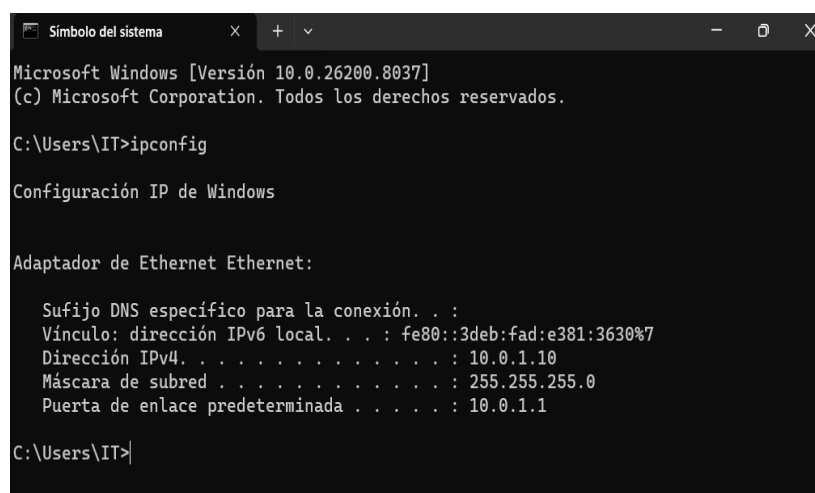
Se ha procedido a la limpieza de servicios innecesarios y a la configuración de seguridad local. Este equipo es el encargado de ejecutar las herramientas de administración remota de pfSense y el acceso al panel de control de Wazuh.

11.2. Validación de Conectividad

Se ha verificado que el equipo recibe correctamente su configuración de red a través del servicio DHCP del pfSense, quedando integrado en la estructura de red del búnker.

Figura 4

Verificación de los parámetros IP en la estación de trabajo Windows 11



```
Símbolo del sistema
Microsoft Windows [Versión 10.0.26200.8037]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\IT>ipconfig

Configuración IP de Windows

Adaptador de Ethernet Ethernet:

    Sufixo DNS específico para la conexión. . . :
    Vínculo: dirección IPv6 local. . . : fe80::3deb:fad:e381:3630%7
    Dirección IPv4. . . . . : 10.0.1.10
    Máscara de subred. . . . . : 255.255.255.0
    Puerta de enlace predeterminada. . . . . : 10.0.1.1

C:\Users\IT>
```

Nota. La captura confirma que el equipo ha obtenido la dirección IPv4 10.0.1.10 y reconoce al PfSense (10.0.1.1) como su puerta de enlace predeterminada, validando la comunicación con el departamento IT.

12. Gestión de Identidades: Windows Server y Active Directory

Para centralizar la autenticación y el control de los 18 empleados, se ha desplegado un controlador de dominio bajo el sistema Windows Server.

12.1. Estructura de Unidades Organizativas (OU)

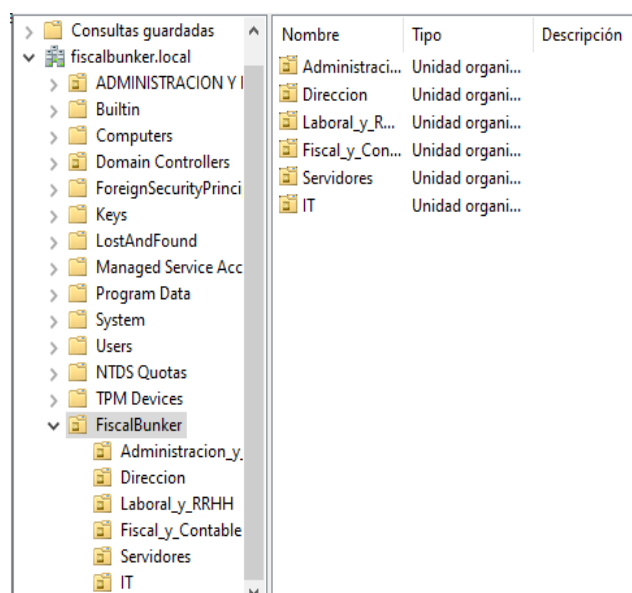
Se ha replicado la estructura departamental de la gestoría (Fiscal, Laboral, Dirección, etc.) dentro del Directorio Activo. Esto permite aplicar Políticas de Grupo (GPOs) específicas, como restricciones de panel de control o mapeo automático de unidades de red.

12.2. Seguridad del Dominio

Se han establecido políticas de contraseñas robustas y bloqueos de cuenta para mitigar ataques de fuerza bruta internos.

Figura 5

Unidades Organizativas en el dominio FiscalBunker.local



Nota. La imagen muestra la creación de la estructura de las Unidades Organizativas creada para la correcta organización por departamentos

13. Persistencia de Datos: Servidor Ubuntu y MariaDB

El activo más crítico, la información financiera, reside en un servidor Linux endurecido para evitar accesos no autorizados.

13.1. Configuración de MariaDB

Se ha desplegado el motor de base de datos MariaDB, configurándolo para que solo acepte conexiones desde las IPs autorizadas de la VLAN de Servidores y la VLAN Fiscal.

13.2. Privilegio Mínimo en Base de Datos

Se han creado usuarios específicos para los contables que carecen de permisos de borrado (DROP) o alteración de tablas (ALTER), limitando su capacidad operativa a la consulta y actualización de registros tributarios.

Figura 6

Configuración de usuarios y privilegios en MariaDB

```
MariaDB [(none)]> CREATE USER 'adminbunker'@'%' IDENTIFIED BY 'FiscalBunker2026.';
Query OK, 0 rows affected (0,005 sec)

MariaDB [(none)]> GRANT ALL PRIVILEGES ON *.* TO 'adminbunker'@'%' WITH GRANT OPTION; FLUSH PRIVILEGES;
Query OK, 0 rows affected (0,003 sec)

Query OK, 0 rows affected (0,001 sec)

MariaDB [(none)]> exit
Bye
administrador_bunker@srv-datos-fb:~$ _
```

Nota. La imagen muestra la creación del usuario administrativo y la asignación de privilegios mediante comandos de SQL, asegurando el control total del servidor de base de datos.

14. Monitorización Proactiva: Sistema SIEM Wazuh

Como última capa de defensa de la infraestructura "Fiscal Bunker", se ha implementado Wazuh para obtener visibilidad total sobre los eventos de seguridad en servidores y puestos de trabajo.

14.1. Despliegue del Manager y Dashboard

Tras evaluar inicialmente el proceso de instalación manual en el host, se identificaron riesgos de inestabilidad derivados de conflictos en los repositorios y dependencias del sistema operativo. Para garantizar la integridad y robustez del proyecto, se optó por el despliegue del servidor Wazuh mediante una imagen OVA (Open Virtual Appliance). Esta solución técnica ofrece un entorno optimizado y funcional "out-of-the-box", eliminando errores de compilación y asegurando la correcta ejecución de todos los servicios de la API y el Dashboard.

Para una operatividad óptima, la interfaz de red del SIEM se configuró en modo adaptador puente (IP 192.168.1.138). Esta configuración permite que el servidor actúe como un nodo real dentro de la red, facilitando la visibilidad bidireccional con los agentes instalados en los endpoints. Asimismo, garantiza que el servidor pueda conectar con los repositorios oficiales para la descarga automatizada de las bases de datos de vulnerabilidades (CVE), manteniendo el sistema actualizado ante amenazas de día cero.

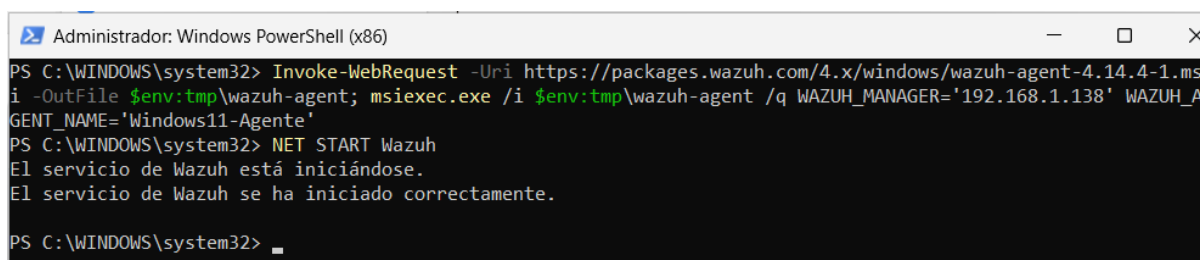
14.2. Despliegue de Agentes

La fase de monitorización se inició con la instalación del agente de Wazuh en el equipo del departamento de IT (Windows 11 con IP 192.168.1.51). El despliegue se realizó mediante scripts de PowerShell, vinculando el nodo directamente con la IP del servidor central.

Tras la instalación, se verificó mediante el gestor de servicios de Windows que el agente se encontraba en estado de ejecución activa. Finalmente, se confirmó desde el Dashboard de Wazuh que el agente aparecía con el estado "Active", validando el inicio de la recolección de telemetría y eventos de seguridad en tiempo real.

Figura 7

Ejecución y despliegue del agente de Wazuh en el sistema objetivo

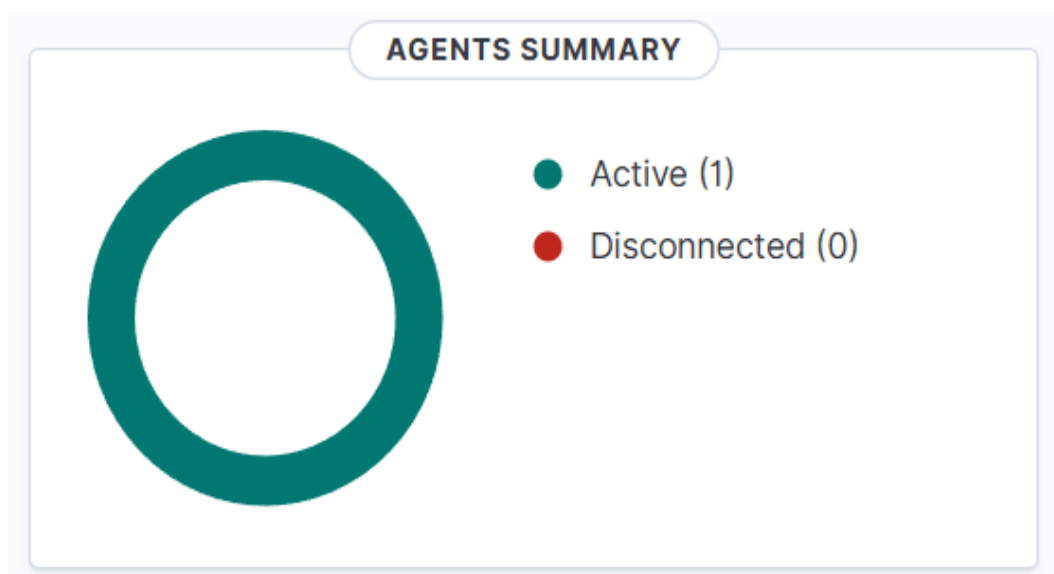


```
Administrador: Windows PowerShell (x86)
PS C:\WINDOWS\system32> Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.14.4-1.msi -OutFile $env:tmp\wazuh-agent; msixexec.exe /i $env:tmp\wazuh-agent /q WAZUH_MANAGER='192.168.1.138' WAZUH_AGENT_NAME='Windows11-Agente'
PS C:\WINDOWS\system32> NET START Wazuh
El servicio de Wazuh está iniciándose.
El servicio de Wazuh se ha iniciado correctamente.
PS C:\WINDOWS\system32>
```

Nota. La captura muestra el uso de powershell para instalar el agente y vincularlo a la IP del servidor SIEM. Se confirma que el proceso finaliza con el inicio correcto del servicio.

Figura 8

Panel de resumen de agentes en la consola de Wazuh



Nota. En la imagen se muestra el estado de salud de los agentes desplegados, confirmando que la estación de trabajo y los servidores están vinculados correctamente

15. Auditoría de Seguridad y Validación del Perímetro

Finalizado el despliegue de la infraestructura, se procedió a realizar una auditoría de seguridad controlada utilizando Kali Linux (IP 192.168.1.129). El objetivo fue validar que las reglas de filtrado en pfSense y la segmentación de VLANs cumplen con los requisitos de seguridad exigidos.

15.1. Análisis de Visibilidad y Reconocimiento Externo

Se ejecutó un escaneo exhaustivo mediante Nmap sobre la interfaz WAN del búnker. Los resultados confirmaron la correcta implementación de la política de "Denegación por Defecto" (Default Deny); la totalidad de los puertos analizados se reportaron en estado *filtered*, demostrando que la infraestructura es invisible ante intentos de reconocimiento externo.

15.2. Verificación de la Estanqueidad de la Red Interna (LAN)

Para validar la robustez de la segmentación mediante el estándar IEEE 802.1Q, se realizó un segundo escaneo dirigido hacia la estación de trabajo crítica. El firewall pfSense interceptó y descartó todos los paquetes dirigidos a la LAN, confirmando que la segmentación impide eficazmente el movimiento lateral y el acceso no autorizado entre departamentos

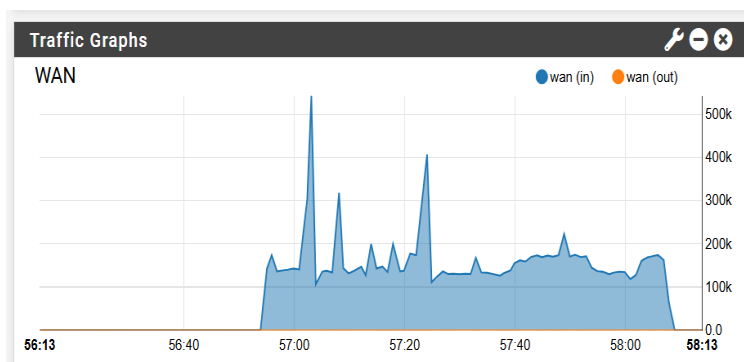
15.3. Evaluación de Resiliencia ante Ataques de Inundación (SYN Flood)

Utilizando la herramienta hping3, se lanzó una inundación de paquetes TCP SYN contra la interfaz WAN para medir la estabilidad de las tablas de estado del firewall.

1. *Disponibilidad.* El núcleo de PfSense gestionó la carga sin bloqueos, manteniendo la CPU en niveles operativos.
2. *Continuidad de negocio.* El tráfico legítimo interno no sufrió interrupciones, validando la capacidad del búnker para mitigar ataques DoS perimetrales sin afectar la productividad.

Figura 9

Monitorización del tráfico WAN durante el ataque de inundación SYN Flood



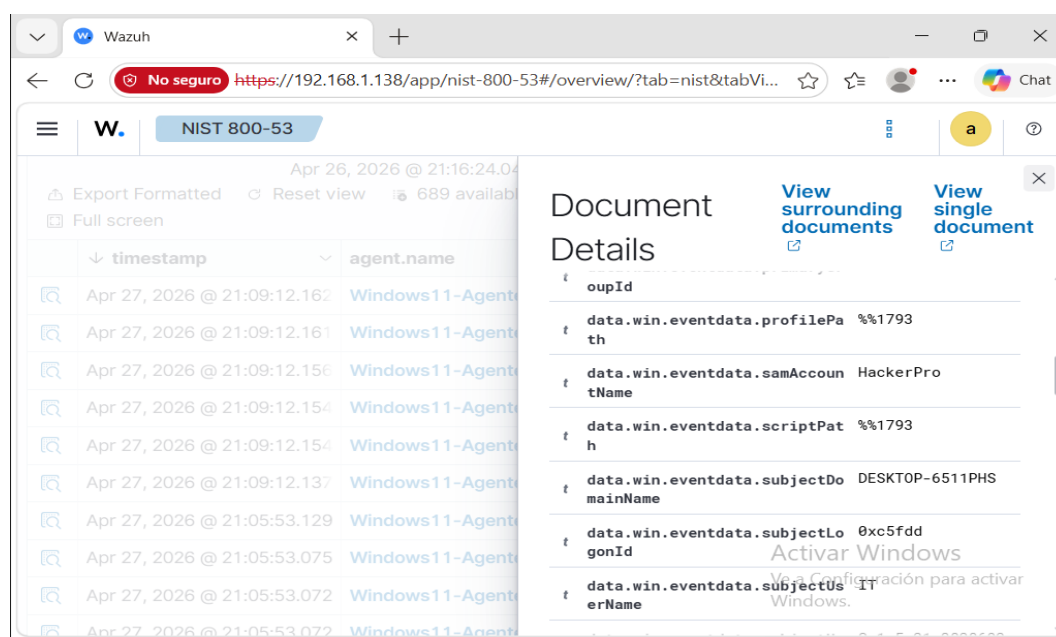
Nota. El gráfico muestra el impacto del ataque realizado con hping3, donde se aprecian picos de tráfico entrante (wan in) superiores a los 500k. También se puede observar que la línea de salida (wan out) confirma que el firewall neutralizó el ataque con éxito sin saturar la red interna.

15.4 Detección de Escalada de Privilegios

Para validar la eficacia del SIEM, se simuló una intrusión en el nodo Windows 11 mediante la creación de una cuenta de usuario local no autorizada y su posterior inclusión en el grupo de Administradores. El agente de Wazuh detectó las modificaciones en los registros de seguridad de forma instantánea, remitiendo una alerta crítica al servidor y demostrando la efectividad de las políticas de auditoría de sistema operativo implementadas.

Figura 10

Evento Wazuh en el que se observa el ID del usuario con privilegios



Nota. La imagen muestra el momento exacto en que el SIEM caza la creación de la cuenta. Al aparecer este nombre en el registro, queda demostrado que el sistema está bien configurado y que avisa al instante de cualquier intento de crear usuarios sin permiso.

15.5 Análisis de ataques de fuerza bruta sobre SMB

Se evaluó la respuesta del SOC ante un ataque de fuerza bruta dirigido al puerto 445(SMB).

Tras habilitar las directivas de auditoría de inicio de sesión, se lanzó un ataque automatizado mediante scripts de Nmap para comprometer las credenciales de administrador.

El panel de *Threat Hunting* de Wazuh registró un incremento masivo de eventos, disparando alertas de nivel de gravedad 12. El sistema proporcionó detalles críticos como la IP de origen del atacante (Kali Linux) e identificó la amenaza bajo el marco MITRE ATT&CK, certificando la capacidad de la infraestructura para detectar y responder a intentos de intrusión en tiempo real.

Figura 11

Evento de Wazuh nivel 12 ante un ataque de fuerza bruta

rule.gdpr	IV_35.7.d, IV_32.2
rule.gpg13	7.10
rule.groups	windows, windows_security, group_changed, win_group_changed
rule.hipaa	164.312.a.2.I, 164.312.a.2.II, 164.312.b
rule.id	60154
rule.level	12
rule.mail	true
rule.mitre.id	T1484
rule.mitre.tactic	Defense Evasion, Privilege Escalation
rule.mitre.technique	Domain Policy Modification
rule.nist_800_53	AC.2, IA.4, AU.14, AC.7
rule.pci_dss	8.1.2, 10.2.5
rule.tsc	CC6.8, CC7.2, CC7.3
timestamp	Apr 28, 2026 @ 21:01:38.076

Nota. En la imagen se observa cómo Wazuh clasifica el ataque con un nivel 12 (crítico).

15.6. Conclusiones de la validación técnica

Tras la finalización de la fase de auditoría y la ejecución de las pruebas de estrés, reconocimiento y monitorización, se confirma que la infraestructura de "Fiscal Bunker" ha alcanzado un estado de madurez técnica del 100%. Los resultados obtenidos permiten extraer las siguientes conclusiones fundamentales:

- *Eficacia de la Segmentación y Estanqueidad.* El uso del estándar IEEE 802.1Q y el endurecimiento (*hardening*) del firewall pfSense han demostrado ser críticos para la seguridad del entorno. Los escaneos de Nmap confirmaron una superficie de exposición nula hacia el exterior y un aislamiento efectivo entre VLANs, mitigando el riesgo de movimiento lateral.
- *Resiliencia ante Ataques de Denegación de Servicio.* Las pruebas de inundación SYN Flood mediante hping3 validaron la capacidad del perímetro para absorber cargas de tráfico malicioso sin comprometer la disponibilidad de los servicios internos ni la continuidad de negocio de la gestoría.
- *Capacidad de Respuesta y Ciberinteligencia.* El despliegue del SIEM Wazuh mediante una imagen OVA en modo puente ha sido el hito definitivo para la seguridad del proyecto. Se ha verificado que el sistema no solo recolecta telemetría, sino que es capaz de identificar, categorizar (Nivel 12) y alertar en tiempo real sobre ataques complejos como la fuerza bruta SMB y la escalada de privilegios.
- *Cumplimiento de Estándares.* La integración de herramientas ofensivas (Kali Linux) y defensivas (Wazuh) bajo un marco de trabajo alineado con MITRE ATT&CK garantiza que la infraestructura cumple con los estándares de ciberseguridad recomendados por el INCIBE para la protección de activos críticos en entornos profesionales.

En definitiva, la arquitectura diseñada no solo es operativa para el flujo de trabajo diario, sino que constituye un ecosistema resiliente, monitorizado y preparado para neutralizar las amenazas del panorama de ciberseguridad actual.

16.TECNOLOGÍA



VMWare

Entorno de virtualización en el que se desarrolla el proyecto



PfSense

Firewall

Creación de VLANs y reglas de ACL



Windows 11 PRO

Estación de trabajo

PC de gestión de IT



Windows Server 2022

Controlador de dominio y directorio activo



Ubuntu Server

Alojará el servidor de BBDD



Wazuh server

Herramienta de monitorización de seguridad y respuesta ante incidentes.



VirtualBox nuevo entorno de virtualización.



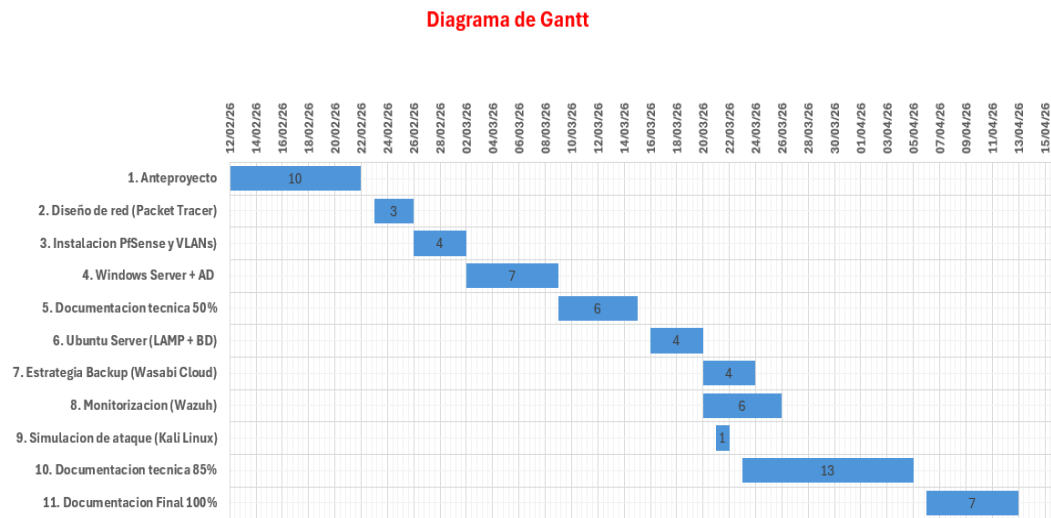
Kali Linux (2026.1) Auditoría de seguridad.

17.METODOLOGÍA

La planificación del proyecto ha avanzado con éxito desde el diseño inicial hasta la implementación y validación técnica total, logrando cumplir el 100% de los objetivos propuestos. Una vez consolidada la infraestructura de red y el controlador de dominio, la fase final es asegurar que el búnker digital fuera capaz de monitorizar y responder correctamente ante las amenazas reales.

Los avances que hemos completado para cerrar este proyecto han sido:

1. *Despliegue del nodo de auditoría.* Se finalizó a instalación y configuración de una estación Kali Linux dentro de la infraestructura. Esta máquina actuó como la herramienta oficial para realizar todas las pruebas de auditoría ofensiva.
2. *Pruebas de intrusión.* Se realizó con éxito pruebas de reconocimiento con Nmap y ataques de denegación de servicio (SYN Flood con hping3). Con esto, se pudo validar que el firewall PfSense es realmente resiliente y mantiene la red invisible desde el exterior.
3. *Migración y optimización.* Decidimos migrar el despliegue del SIEM a un entorno ova y reconfigurar la red en modo puente. Este cambio fue fundamental para simular un entorno real y garantizar que el SOC funcionara correctamente.
4. *Monitorización activa.* Instalamos los agentes de Wazuh en las máquinas Windows, lo que me permitió validar la estrategia de defensa en profundidad. Gracias a esto, el sistema ahora detecta en tiempo real ataques de fuerza bruta por SMB y cualquier intento de escalada de privilegios.

Figura 12*Diagrama de Gantt*

Nota. El diagrama de Gantt detalla el desarrollo de proyecto, abarcando desde el anteproyecto hasta la documentación final.

18. TRABAJOS FUTUROS

Una vez que el búnker digital ha alcanzado su plena operatividad en el entorno local, se han identificado dos líneas de expansión estratégica para elevar los estándares de disponibilidad y defensa proactiva:

- *Implementación de Seguridad Profunda (IDS/IPS con Suricata).* Una evolución crítica para la red es la integración de Suricata como motor de inspección de paquetes de alto rendimiento. A diferencia de la monitorización basada en agentes, Suricata permitiría analizar el tráfico de red en tiempo real, detectando y bloqueando automáticamente escaneos de puertos avanzados, ataques de desbordamiento de búfer o firmas de malware conocido antes de que alcancen los endpoints. Su integración dentro de pfSense permitiría correlacionar alertas de red con los eventos de sistema de Wazuh, creando un ecosistema de defensa XDR (Extended Detection and Response) mucho más potente.
- *Transición a Entornos Híbridos y Backup Off-site (Wasabi).* Aunque la infraestructura actual es robusta, la dependencia de un único servidor físico presenta un punto de fallo único ante desastres catastróficos. Se propone la integración con servicios de almacenamiento en la nube como Wasabi, aprovechando su tecnología de inmutabilidad de datos para proteger los backups contra el borrado accidental o ataques de ransomware.
- *Plan de Recuperación ante Desastres (DRP).* Esta línea de trabajo se orienta a configurar un sistema de recuperación que permita levantar los servicios críticos en la nube en tiempos mínimos (RTO reducido). De este modo, ante un fallo total del hardware físico, la gestoría mantendría la continuidad de negocio, garantizando que la información de los clientes permanezca accesible y segura sin importar las incidencias en las instalaciones locales.

19.CONCLUSIONES

Tras completar las fases de este proyecto, se concluye que la infraestructura de FiscalBunker ha logrado pasar de un diseño teórico a un entorno virtualizado funcional y verificado. Aunque el despliegue presentó desafíos técnicos significativos, especialmente en la estabilidad del SIEM, se han alcanzado los siguientes resultados:

- *Segmentación de Red.* Se ha comprobado que la implementación de las VLANs en pfSense cumple con su función básica de aislamiento. Las pruebas con Nmap demostraron que el tráfico entre departamentos está restringido, lo que ayuda a contener posibles incidentes y limita el movimiento lateral dentro de la red.
- *Comportamiento del Firewall.* El perímetro basado en pfSense ha mostrado ser efectivo frente a escaneos externos, manteniéndose opaco ante el reconocimiento. Asimismo, las pruebas de estrés con hping3 confirmaron que el sistema mantiene la disponibilidad de la red interna bajo carga de tráfico SYN Flood.
- *Viabilidad de la Monitorización.* Tras corregir los errores de instalación mediante el uso de una imagen OVA, se ha validado que Wazuh es capaz de centralizar eventos de seguridad. Se ha verificado la recepción de alertas críticas (Nivel 12) ante ataques de fuerza bruta SMB y modificaciones de usuarios, lo que otorga una visibilidad necesaria para la gestión de incidentes.
- *Gestión de Datos.* La arquitectura de base de datos y los procesos de backup configurados establecen una base mínima de recuperación. Esto permite que la gestoría cuente con una estrategia de protección de datos frente a fallos de integridad o ataques de ransomware.

En definitiva, el proyecto demuestra que es viable montar un entorno de red segmentado y monitorizado con herramientas de código abierto. Si bien siempre hay margen de mejora en el endurecimiento de las políticas, los objetivos principales de seguridad, visibilidad y control de acceso se han cumplido de forma satisfactoria para las necesidades de la gestoría.

20.REFERENCIAS

Cisco Systems, Inc. (2023). *Cisco Digital Network Architecture (Cisco DNA).*

<https://www.cisco.com/>

IEEE Computer Society. (2014). *IEEE Standard for Local and metropolitan area networks--Bridges and Bridged Networks (IEEE Std 802.1Q-2014).*

<https://standards.ieee.org/>

INCIBE. (2023). *Guía de ciberseguridad para pymes: Cómo proteger tu negocio frente a las amenazas digitales.* Instituto Nacional de Ciberseguridad.

<https://www.incibe.es/pyme/guias/guia-ciberseguridad-pyme>

Lyon, G. F. (2009). *Nmap network scanning: The official Nmap project guide to network discovery and security scanning.* Insecure.

Sanfilippo, S. (s.f.). *hping3: Active network smashing tool.*

<http://www.hping.org/>